

# Initial Post

## Initial Post

I would recommend VeraCrypt over BitLocker to a technically competent user who values transparency and cross-platform compatibility, although the suggestion comes with conditions. VeraCrypt's open-source architecture allows independent verification of its cryptographic implementation, aligning with secure software development principles that stress transparency and peer review (Olmsted, 2024). BitLocker, by contrast, is proprietary; yet its integration with Trusted Platform Module technology can reduce the chance of user misconfiguration and therefore suits non-expert Windows users better. However, this abstraction also reduces user visibility into the underlying cryptographic processes.

VeraCrypt's security depends heavily on correct configuration. Weak passwords, poor keyfile management or incorrect parameter choices can significantly undermine the intended security guarantees (Tan et al., 2020). The complete absence of built-in recovery mechanisms also creates a serious availability risk: lost credentials mean permanent data loss.

Independent audits remind us that even mature tools carry implementation-level risks. Quarkslab's assessment highlighted weaknesses in keyfile handling and potential AES side-channel vulnerabilities (Quarkslab, 2016). The later Fraunhofer SIT and BSI study raised further concerns about deprecated hash functions and random-number generation, while still judging the software acceptable for many uses when configured properly (Fraunhofer SIT and BSI, 2020).

An ontology of VeraCrypt's weaknesses can be organised by severity using three linked entities: Weakness, Trigger and Impact. This model emphasises that risk emerges not from isolated weaknesses, but from the interaction between technical flaws and user behaviour.

## High severity

User misconfiguration (e.g. weak passwords), triggered by poor credential practices,

reduces resistance to brute-force attacks. The absence of recovery mechanisms, triggered by credential loss, leads to permanent data inaccessibility.

### **Medium severity**

Limited hardware integration, triggered by the lack of TPM-like support, increases reliance on user-managed secrets.

### **Low severity**

Usability complexity, triggered by difficulty in correct configuration, may prompt insecure behaviours such as storing passwords externally (Reichmann et al., 2020).

From a user perspective these risks vary by context. Someone encrypting a disk that stores bank details would see the high-severity weakness of missing recovery mechanisms become critical if credentials are lost, directly destroying access to financial records. Even a low-severity usability issue could push the same person toward unsafe shortcuts (Reichmann et al., 2020). Such patterns illustrate a wider truth in secure development: human factors often amplify technical shortcomings.

Overall, VeraCrypt suits informed users who can manage its demands. BitLocker offers a more reliable default for general users because of smoother integration and fewer technical decisions.

## **References**

Fraunhofer Institute for Secure Information Technology (SIT) and Federal Office for Information Security (BSI) (2020) *Security evaluation of VeraCrypt*. Bonn/Darmstadt: BSI/Fraunhofer SIT. Available at:

[https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/Studies/Veracrypt/Veracrypt.pdf?\\_\\_blob=publicationFile&v=1](https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/Studies/Veracrypt/Veracrypt.pdf?__blob=publicationFile&v=1)

Olmsted, A. (2024) *Security-driven software development*. Birmingham: Packt Publishing. Available at:

<https://www.packtpub.com/en-us/product/security-driven-software-development-9781835461174>

Quarkslab (2016) *VeraCrypt 1.18 security assessment*. Technical Report 16-08-215-REP. Paris: Quarkslab. Available at:  
<https://blog.quarkslab.com/resources/2016-10-17-audit-veracrypt/16-08-215-REP-VeraCrypt-sec-assessment.pdf>

Reichmann, A., Gerber, N., Volkamer, M. et al. (2025) 'Bridging the gap between usable security research and open-source practice: lessons from a long-term engagement with VeraCrypt'. *Proceedings of the 2025 CHI Conference on Human Factors in Computing Systems*. Available at:  
<https://casa.rub.de/forschung/publikationen/detail/bridging-the-gap-between-usable-security-research-and-open-source-practice-lessons-from-a-long-term-engagement-with-veracrypt>

Tan, X. et al. (2020) [Module reading on encryption usability and configuration risks]. No public URL available.